

Network Attacks: ARP Spoofing & Traffic Interception

The LAN Is a Shared Medium

In a switch network, unicast only goes to one MAC â€” normally. But ARP (Address Resolution Protocol) has no authentication: any host can claim any IP.

ARP Spoofing: The Classic MITM

Attacker sends ARP replies: "I am the gateway" (to the victim) and "I am the victim" (to the gateway)

Victim sends traffic to attacker â€” attacker relays to the gateway (acting as MITM)

Attacker reads EVERYTHING the victim sends

```
# BetterCap / Ettercap â€” the standard tools
bettercap -iface eth0
# in the UI: net.probe on; set arp.spoof.targets 192.168.1.10; arp.spoof on
```

Why it works: ARP has zero security. Fast, invisible, no wires needed.

Defense Against ARP Spoofing

Dynamic ARP inspection (switch feature) â€” bind IPâ†’MACâ†’port

Static ARP entries

Remember that **encryption makes MITM useless** â€” even if traffic is intercepted, it's unreadable.

Sniffing & SSL Stripping â€” The Old Classic

Without TLS:

```
# sniff traffic on the wire (switchport/same-hub or ARP-spoof)
tcpdump -i eth0 port 80 -A
# credentials in plaintext: you just read the login!
```

SSL stripping: attacker intercepts, downgrades https:// to http:// at their position, relays TLS to the real site, and reads the plaintext in between. Mitigation: HSTS (**Strict-Transport-Security**) forces browsers to https " kills the strip.

HSTS: The Tool That Killed SSL Stripping

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

Once seen, the browser refuses ALL http " the strip can't happen. Preload lists extend it globally.

DNS & Other Bugs

DNS cache poisoning " fake replies redirect names (fix: DNSSEC)
Rogue DHCP " give out yourself as gateway/DNS (fix: DHCP snooping)
MAC flooding " flood to fill the switch CAM table " acts like a hub (fix: switch port security)

The Big Lesson

The intercept is easy. The **value** comes from what's readable:

Plaintext protocols **telnet**, **http**, **FTP** " complete compromise
Encrypted **https**, **ssh** " the MITM is defeated (unless stripped)

Defender action plan worldwide: encrypt everything (HTTPS/HSTS, SSH), and add MITM-resistant layers (wire encryption, network segmentation, dynamic ARP inspection). The attack's premise disappears.

[← SSRF, File Uploads & Auth At...](#)

Module complete ✓